

BLOCKCHAIN TECHNOLOGY & APPLICATION

区块链安全技术

王勇超

2026.5.25



世上有没有绝对安全？

没有绝对的安全
只有攻防的博弈

本讲核心内容

01 共识安全

02 合约安全

03 隐私安全

04 网络层安全

PART 01

共识安全

主流共识机制

核心机制：谁来记账？



PoW 工作量证明

矿工通过计算复杂的数学题来竞争记账权，算力越大，获得记账权的机会越大。

代表：比特币、以太坊（早期）



PoS 权益证明

根据持币数量和时间（币龄）分配记账权，持有的币越多，获得记账权的机会越大。

代表：以太坊（现在）、Cardano



DPoS 委托权益证明

持币者投票选出“超级节点”代表进行记账，实现了处理效率与去中心化程度的较好平衡。

代表：EOS、TRON

共识机制的安全对比

不同共识机制基于不同信任模型，具备差异化的安全特性与潜在风险



PoW 工作量证明

核心安全依赖于巨大的算力投入，攻击成本极高。主要风险是51%算力攻击，但对主流链而言，因经济成本过高通常得不偿失。



PoS 权益证明

用代币持有量与币龄代替算力，大幅降低能耗。主要风险是“长程攻击”（攻击者利用私钥签名废弃旧区块，试图创建更长的无效历史链）和“无利害关系问题”，即攻击者可能尝试创建无效的历史分叉链。



DPoS 委托权益证明

由持币者投票选出见证人节点进行打包记账，出块效率极高。主要风险是存在中心化倾向，且可能出现大户“贿选”垄断投票权的问题。

什么是51%算力攻击？



当某个节点或组织掌握了全网**超过 51% 的算力**（或权益）时，它就拥有了修改区块链账本的**“绝对话语权”**。

💡 通俗理解：就像在一个民主投票系统中，一个人掌握了**超过一半的选票**，他就可以随意决定投票结果。

实例：村长记账



村里有100人，大家约定：**超过半数（51人）**认可的账本，就是唯一的真账本。



如果有**51个坏人串通**，他们就可以强行写下一笔假账：“张三欠我们100万”，并宣布这是真账本。



在PoW机制中，**算力就是投票权**。掌握了全网51%的算力，就掌握了“指鹿为马”的权力。

51%攻击能做什么？



核心威胁：双花攻击 (Double Spending)



1. 正常支付

攻击者用 10 BTC 买车，交易在**主链**上确认，车主交车。



2. 秘密造链

攻击者在私下挖出一条**更长的链**，把这 10 BTC 转回自己。



3. 覆盖主链

公布更长链后，长链成为主链，**原交易被撤销**，车主两空。

51%攻击不能做什么？

- ✘ 不能**凭空造钱**（必须遵守系统的货币发行规则）
- ✘ 不能**修改别人的密码**（受非对称加密算法保护）
- ✘ 不能**动用别人的资产**（没有别人的私钥，无法生成有效签名）



结论：51%攻击只能破坏 共识（历史记录）
无法打破 密码学（数学规律）



**为什么比特币至今
没有被51%攻击？**

答案：攻击成本远大于收益

↑ 极高的成本

购买全网51%的矿机并支付电费，需要**数百亿美元**资金，且难以在市场上购得足够硬件。

↓ 极低的收益

一旦发生51%攻击，公众信任将崩溃，**币价可能归零**，攻击者获得的币将一文不值。

 结论：比特币的安全建立在 **经济博弈论** 上。做诚实的矿工比做攻击者 **更赚钱**

长程攻击

PoS/DPoS 共识里，攻击者拿到历史上的验证者私钥，从很久之前的区块开始，偷偷挖一条新链，因为 PoS 不需要算力，成本极低。等新链更长后，试图让全网节点切换到这条假链，篡改整个历史。

长程攻击的防范方法



1. 检查点机制 (Checkpointing)

定期固化区块状态，形成不可篡改的检查点，锁死历史，使攻击者无法回滚到检查点之前。



2. 经济惩罚 (Slashing)

要求验证者抵押代币，若参与恶意分叉或攻击，将被罚没全部或部分抵押金，大幅提高攻击成本。



3. 前向安全密钥 (Forward Security)

验证者私钥一次性使用，每次出块后自动销毁，即使历史私钥泄露，也无法用于伪造新的区块。

PART 02

合约安全

智能合约的“阿喀琉斯之踵”

优势：不可篡改

代码一旦部署，任何人（包括开发者）都**无法修改**，保证规则公平、透明。

❌ 劣势：无法修复

若代码存在**漏洞（Bug）**，无法像传统软件那样打补丁，黑客可被动利用漏洞。

⚠️ 结论：在智能合约的世界里，**“代码即法律”**。若法律写错，黑客可合法地拿走你的钱。

著名安全事件：The DAO 攻击

区块链史上的“至暗时刻” (2016年)

 **背景**：去中心化风投基金 The DAO 筹集了创纪录的 **1.5亿美元**。

 **灾难**：黑客利用智能合约中的漏洞，盗取了价值 **5000万美元** 的以太币。

 **后果**：为了挽回损失，以太坊社区被迫进行**硬分叉**，分裂为 ETH 和 ETC。

 **教训**：一行写错的代码，可能导致整个生态系统的分裂。

漏洞解析：重入攻击 (Reentrancy)

1. 检查余额

```
require(balance > 0);
```

2. 发送资金 (漏洞点)

```
send(balance);
```

3. 更新余额

```
balance = 0;
```



致命的执行顺序： 恶意合约在第2步被触发时，可再次调用提款，在第3步（清零余额）执行前重复提现，导致资金被逐步掏空。

实例：ATM机吐钱漏洞

正常的 ATM 机

- ➡ 检查余额 (有100元)
- ➡ **扣除余额** (变为0元)
- ➡ 吐出钞票 (100元)

有漏洞的 ATM 机

- ➡ 检查余额 (有100元)
- ➡ 吐出钞票 (100元)
-  **黑客打断：再取100元！**
-  **ATM检查余额 (还没扣, 还是100元)**
-  **吐出钞票 (100元) ... 无限循环**
- ➡ **扣除余额 (永远执行不到)**

防御措施：如何避免漏洞？



1. 第三方安全审计

部署前，必须聘请专业的安全公司对代码进行**全面审计**。



2. 严格的代码规范

遵循最佳实践，例如：在转账前**先扣除余额**（防重入攻击）。



3. 漏洞赏金计划

设立高额奖金（Bug Bounty），鼓励白帽黑客**主动报告漏洞**。

PART 03

隐私安全



**账本全网公开，
是不是意味着毫无隐私？**

澄清概念：匿名性 vs 隐私性



匿名性 (Pseudonymity)

“我不知道你是谁，但我能看到你做了什么。”

地址是公开的，**关联后可被追踪。**



隐私性 (Privacy)

“我不知道你是谁，也不知道你做了什么。”

隐藏身份、**金额与交易双方**

隐私保护黑科技：零知识证明 (ZKP)

 **核心思想：**证明者能够在**不向验证者提供任何有用信息**的情况下，使验证者相信某个论断是正确的。



1. 完备性

如果论断是真的，诚实的验证者**一定会被说服**。



2. 可靠性

如果论断是假的，欺骗者**极难**说服诚实的验证者。



3. 零知识性

验证者除了知道“论断是真的”之外，**得不到任何其他信息**。

实例：如何证明我知道，但不告诉你？

 **场景**：在一张密密麻麻的巨幅海报中，你找到了隐藏的“目标人物”。你想向朋友证明你找到了，但 **不想暴露他的具体位置**。

传统方法

直接在海报上指给朋友看。朋友不仅知道你找到了，也知道目标的具体坐标。
代价：隐私泄露。

零知识证明

用一张更大的**纯黑硬纸板**，挖一个小洞盖在海报上，让目标从洞中露出。 **结果：完美证明。**



朋友确信你找到了（ **证明成功** ），
但他没有获得任何位置信息（ **零知识** ）。

PART 04

网络安全

DDoS攻击?



分布式拒绝服务攻击（DDoS），通过控制大量“肉鸡”向目标节点发送海量请求，耗尽其带宽、CPU、内存等关键资源，最终导致目标服务器瘫痪，无法向合法用户提供正常服务。



通俗理解：就像成千上万的人同时拨打同一个客服热线，瞬间将线路占满，导致真正有业务需求的用户无法打通电话，享受不到服务。

DDoS攻击的防御策略



1. 节点IP隐藏与保护

通过Tor网络或VPN隐藏节点的真实IP地址，增加攻击者定位和发起有效攻击的难度。



2. 流量清洗与限速机制

部署防火墙和专业流量清洗服务，精准识别并过滤掉恶意流量，并对单个IP请求频率实施严格限制。



3. 分布式节点部署

通过在全球范围内部署多个节点，避免单点故障，确保即使部分节点遭受攻击，整个网络依然保持高可用性。



课后思考

量子计算会摧毁区块链吗？

如果现有的非对称加密算法被破解，
比特币该何去何从？